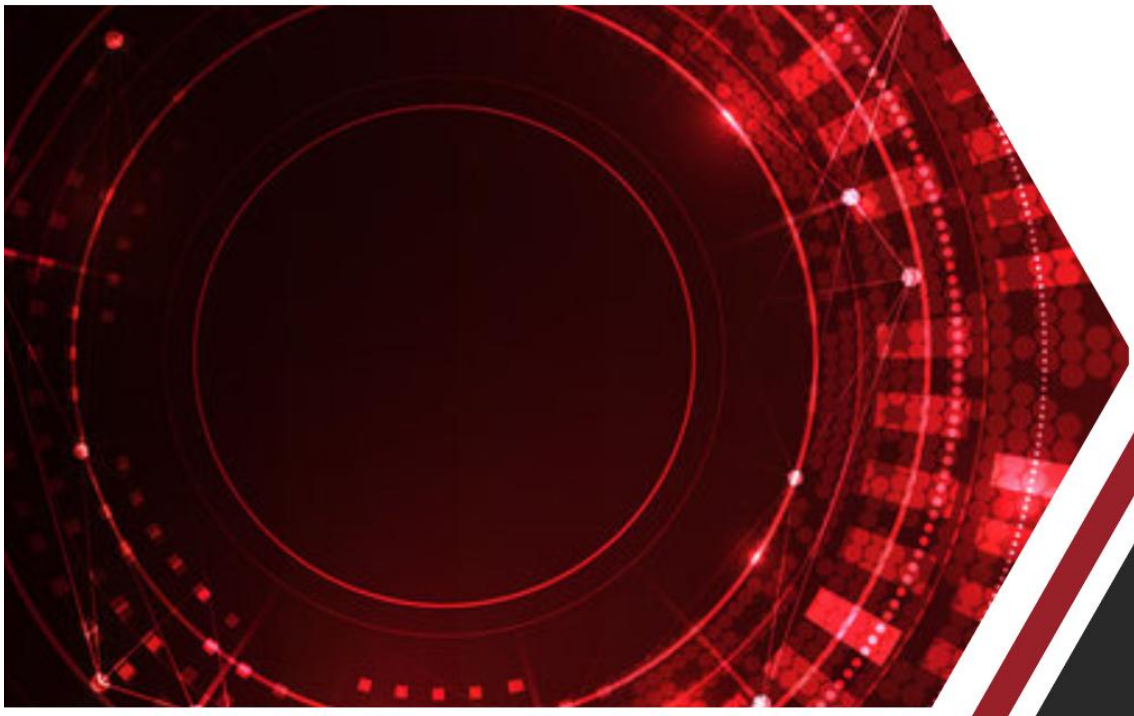
Skyline Technologies

TP Sécurité des Applications ANDROID



BROUGHT TO YOU BY

Antoine ENGASSER
Antonyn HIBOUX

Table des Matières

US1 — Téléchargement et vérification de l'APK 4
Vérification d'intégrité 4
Résultat 4
US2 — Analyse automatisée avec MobSF 4
Résultats — Nickel 2.12.0 4
Distribution des findings 4
Findings HIGH 4
Points positifs (SECURE) 5
US3 — Extraction de fichiers 5
US4 — Décompilation avec Apktool 5
US5 — Analyse du manifest et recherche de secrets 6
5.1 Flags critiques de l'application 6
5.2 Secrets critiques dans strings.xml 6
5.3 DevSettingsActivity en production 7
5.4 Composants Pushwoosh non protégés 7
5.5 Permissions sensibles 7
5.6 SDKs tiers identifiés 7
US6 — Recompilation de l'APK 8
Log de build (Apktool 2.9.3) 8
US7 — Signature de l'APK 8
Résultat apksigner verify 8
US8 — Vérification Firebase 9
Résultat 9
US9 — Synthèse des vulnérabilités 10
Recommandations 10
US10 — Politique de sécurité mobile 11
Développement 11
Distribution 11
SDKs tiers 11
Permissions 11
Terminaux 11
US11 — Choix d'une solution MDM 11
Recommandation 12
Politiques MDM recommandées 12
Annexes 13
A. Environnement technique 13

B. Structure GitHub du projet..... 13

US1 — Téléchargement et vérification de l'APK

L'APK fourni par le PO a été réceptionné et vérifié par chaque membre du groupe avant toute manipulation.

Vérification d'intégrité

```
sha256sum app.apk
```

Résultat

```
f01f08c8b6e2fe4612e81bc7e3a3ba9440dad0d7a962f4e67640390dd721d528  app.apk
```

Attribut	Valeur
Nom du fichier	app.apk
Taille	24 325 620 octets (~23,2 Mo)
Type détecté	Android package (APK), with AndroidManifest.xml
SHA-256	f01f08c8b6e2fe4612e81bc7e3a3ba9440dad0d7a962f4e67640390dd721d528

Le hash SHA-256 a été identique sur les trois postes de travail. La base de travail est commune.

US2 — Analyse automatisée avec MobSF

L'APK a été soumis à MobSF v4.5.0 via la plateforme en ligne mobsf.live (scan statique).

Résultats — Nickel 2.12.0

Métrique	Valeur
Score de sécurité	49 / 100
Grade	B
Risque global	Medium Risk
Trackers vie privée	3 User/Device Trackers

Distribution des findings

Sévérité	Nombre
High	3
Medium	20
Info	2
Secure	2
Hotspot	1

Findings HIGH

Source	Description
MANIFEST	Installation possible sur Android 4.4–4.4.4 non patché (minSdk=19)
MANIFEST	Cleartext traffic activé (android:usesCleartextTraffic=true)
CODE	Chiffrement CBC avec padding PKCS5/PKCS7 — vulnérable aux attaques padding oracle

Points positifs (SECURE)

Source	Description
CODE	Détection de root présente dans le code
CODE	SSL certificate pinning implémenté (protection MITM)

US3 — Extraction de fichiers

L'APK est une archive ZIP standard. L'extraction se fait sans décompilateur.

```
unzip app.apk AndroidManifest.xml -d apk_extracted/
unzip app.apk classes.dex -d apk_extracted/
sha256sum apk_extracted/AndroidManifest.xml
sha256sum apk_extracted/classes.dex
```

Fichier	SHA-256
AndroidManifest.xml	80b9b101e3bf02f03eec4f2c9c9ccf4d61403612e1435949b51cec8b85d7a276
classes.dex	57898c5978715da96560ed2692b4a8fa1a8e914b37988dcf369cc59951f6c429

L'APK contient un seul fichier classes.dex — code non multidex, inférieur à la limite des 65 536 méthodes Dalvik.

US4 — Décompilation avec Apktool

Apktool reconstitue les ressources lisibles : manifest XML, code smali, res/.

```
java -jar apktool.jar d app.apk -o app_src/
# I: Using Apktool 2.9.3
# I: Decoding AndroidManifest.xml with resources...
# I: Baksmaling classes.dex...
# I: Copying assets and libs...
```

> *Note : Apktool 2.7.0 a échoué sur des noms de fichiers contenant '$' (res/drawable-v21/) générés par React Native. La mise à jour vers 2.9.3 a résolu le problème.*

Dossier/Fichier	Contenu
AndroidManifest.xml	Manifest lisible en XML
apktool.yml	Métadonnées de décompilation
res/values/strings.xml	Ressources texte — contient les secrets (cf. US5)
smali/	Bytecode Dalvik en format assembleur smali

Dossier/Fichier	Contenu
kotlin/	Bibliothèques Kotlin
lib/	Bibliothèques natives (.so)

US5 — Analyse du manifest et recherche de secrets

5.1 Flags critiques de l'application

Flag	Valeur	Évaluation
android:allowBackup	false	Positif — backup ADB désactivé
android:usesCleartextTraffic	true	Critique — HTTP non chiffré autorisé
android:compileSdkVersion	28 (Android 9)	Info
minSdkVersion	19 (Android 4.4)	Haute — versions non patchées supportées

5.2 Secrets critiques dans strings.xml

> *Finding majeur : le fichier res/values/strings.xml contient en clair des clés d'accès actives à des services tiers de production.*

Clé	Valeur	Sévérité
google_api_key	AIzaSyBTgztvImsUfMWDa41PCrDWAj7dmyIDhUg	**Critique**
google_crash_reporting_api_key	AIzaSyBTgztvImsUfMWDa41PCrDWAj7dmyIDhUg	**Critique**
firebase_database_url	https://application-client-nickel.firebaseio.com	**Critique**
default_web_client_id	717748501407-v621...apps.googleusercontent.com	**Haute**
google_app_id	1:717748501407:android:e0cdeb712e27275d	**Haute**
PUSHWOOSH_APPID	DDF11-D1BF9	**Haute**
ENVIRONMENT	production	**Haute**
google_storage_bucket	application-client-nickel.appspot.com	Moyenne
project_id	application-client-nickel	Moyenne
com.crashlytics.android.build_id	9ad6d741-4e10-4abd-9f12-163a0e3fb0b2	Faible

5.3 DevSettingsActivity en production

```
<activity android:name="com.facebook.react.devsupport.DevSettingsActivity"/>
```

Cette activité React Native de debug est présente sans exported="false". Elle permet d'activer le rechargement JS à chaud ou de pointer l'app vers un bundle JS arbitraire. Sa présence en build de production est une erreur de configuration.

5.4 Composants Pushwoosh non protégés

Composant	Problème
PushwooshSharedDataProvider	exported=true sans permission — données push lisibles par toutes les apps
FcmRegistrationService	intent-filter sans protection d'accès
PushFcmIntentService	intent-filter sans protection d'accès
RNDeviceInfo.RNDeviceReceiver	exported=true sans permission

5.5 Permissions sensibles

Permission	Catégorie	Justification
READ_CONTACTS	Dangereuse	Non justifiée pour une app bancaire
WRITE_EXTERNAL_STORAGE	Dangereuse	Stockage partagé accessible par toutes les apps
USE_FINGERPRINT	Dangereuse	Légitime — authentification biométrique
RECEIVE_BOOT_COMPLETED	Normale	Push au démarrage — à justifier

5.6 SDKs tiers identifiés

SDK	Origine	Risque
Firebase Analytics / Crashlytics / Messaging	Google (US)	Transfert de données hors EU
Pushwoosh	Russie	Alerte DHS 2022 — souveraineté des données
React Native	Meta (US)	Surface d'attaque bundle JS
Amazon Device Messaging	Amazon (US)	—

US6 — Recompilation de l'APK

```
java -jar apktool.jar b app_src/ -o rebuilt.apk
```

Log de build (Apktool 2.9.3)

```
I: Using Apktool 2.9.3
I: Checking whether sources has changed...
I: Building resources...
I: Copying libs... (/lib)  Copying libs... (/kotlin)
I: Building apk file...
I: Built apk into: rebuilt.apk
```

Fichier	Taille
app.apk (original)	24 Mo
rebuilt.apk (recompilé)	23 Mo

L'écart de taille est normal — Apktool recompresse différemment les ressources sans altérer le contenu applicatif.

US7 — Signature de l'APK

```
keytool -genkey -v -keystore test.keystore -alias testkey -keyalg RSA -keysize 2048 -validity 10000
apksigner sign --ks test.keystore --ks-key-alias testkey --out rebuilt_signed.apk rebuilt.apk
apksigner verify --verbose rebuilt_signed.apk
```

Résultat apksigner verify

Schéma	Statut	Signification
v1 — JAR signing	✓ true	Compatible Android < 7. Seul = vulnérable à Janus
v2 — APK Signature Scheme v2	✓ true	Obligatoire depuis Android 7. Couvre l'APK entier
v3 — APK Signature Scheme v3	✓ true	Rotation de clé — recommandé depuis Android 9
v4 — APK Signature Scheme v4	✗ false	ADB incremental install — non critique
SourceStamp	✗ false	Métadonnée optionnelle — non requis

La signature v1+v2+v3 neutralise la vulnérabilité Janus remontée par MobSF sur l'APK original.

US8 — Vérification Firebase

L'URL Firebase identifiée dans strings.xml :

```
<string name="firebase_database_url">https://application-client-nickel.firebaseio.com</string>
curl -s "https://application-client-nickel.firebaseio.com/.json"
```

Résultat

```
{ "error" : "Permission denied" }
```

Critère	Résultat
Base Firebase accessible publiquement	Non — Permission denied
Règles de sécurité configurées	Oui
Fuite de données via accès anonyme	Non

La base est protégée en lecture anonyme. Cependant, la clé API Google et l'URL Firebase étant exposées dans strings.xml, un attaquant peut tenter une authentification avec des credentials volés ou cibler d'autres services Google du projet.

US9 — Synthèse des vulnérabilités

Outil	Score	Grade	Risque
MobSF v4.5.0	49/100	B	Medium Risk

ID	Source	Vulnérabilité	Sévérité
V01	MANIFEST	minSdk=19 — Android 4.4 non patché supporté	Haute
V02	MANIFEST	usesCleartextTraffic=true — HTTP non chiffré autorisé	Haute
V03	CODE	Chiffrement CBC/PKCS7 — vulnérable aux attaques padding oracle	Haute
V04	CERTIFICATE	Vulnérabilité Janus (CVE-2017-13156)	Moyenne
V05	MANIFEST	Composants Pushwoosh exportés sans protection	Moyenne
V06	CODE	Stockage externe accessible en R/W	Moyenne
V07	CODE	Utilisation de MD5 (hash obsolète)	Moyenne
V08	CODE	Requêtes SQL brutes — risque d'injection SQL	Moyenne
V09	CODE	Générateur de nombres aléatoires non sécurisé	Moyenne
V10	FIREBASE	Firebase Remote Config activé	Moyenne
V11	TRACKERS	3 trackers vie privée (Firebase, Crashlytics, Pushwoosh)	Moyenne
V12	STRINGS.XML	Clé API Google exposée en clair	Critique
V13	STRINGS.XML	URL Firebase Realtime DB exposée en clair	Critique
V14	STRINGS.XML	OAuth Client ID Google exposé	Haute
V15	STRINGS.XML	Pushwoosh App ID DDF11-D1BF9 exposé	Haute
V16	STRINGS.XML	Endpoints API bancaires production en clair	Haute
V17	MANIFEST	DevSettingsActivity sans exported=false en production	Haute
V18	PERMISSIONS	READ_CONTACTS non justifié fonctionnellement	Moyenne
V19	STRINGS.XML	Strings de debug React Native en build production	Moyenne
V20	CODE	Logs applicatifs potentiellement sensibles	Info

Recommandations

- **V01 — minSdk=19 :** Relever minSdkVersion à 26 (Android 8.0) minimum.
- **V02 — Cleartext :** Ajouter une network_security_config.xml désactivant le cleartext sur tous les domaines.
- **V03 — CBC/PKCS7 :** Migrer vers AES-GCM (mode AEAD) — pas vulnérable aux attaques padding oracle.
- **V05 — Pushwoosh :** Ajouter exported="false" sur tous les composants Pushwoosh. Évaluer le remplacement par FCM.
- **V12-V16 — Secrets :** Auditer le code source pour supprimer toutes les clés en dur. Utiliser Android Keystore.
- **V09 — RNG :** Remplacer java.util.Random par java.security.SecureRandom pour tout usage sécuritaire.

US10 — Politique de sécurité mobile

Développement

- Aucune clé API, secret ou URL interne ne doit être compilée en dur dans le binaire.
- Le mode debug doit être désactivé en production (DevSettingsActivity absente ou exported=false).
- Communications réseau intégralement chiffrées — TLS 1.2 minimum, TLS 1.3 recommandé.
- Certificate pinning obligatoire pour les endpoints bancaires et d'authentification.
- Données sensibles interdites sur le stockage externe.
- Conformité OWASP Mobile Security Testing Guide (MSTG) obligatoire.

Distribution

- Distribution exclusivement via stores officiels (Google Play, Apple App Store) ou MDM interne.
- Signature RSA 2048 bits minimum, schéma v2 ou v3 obligatoire.
- Processus de revue sécurité (SAST + analyse manuelle) requis avant publication.

SDKs tiers

- Tout SDK dans une application financière doit faire l'objet d'une analyse de risque documentée.
- Les SDKs dont la conformité RGPD ne peut être garantie sont interdits.

Permissions

- Chaque permission Android doit être justifiée par un besoin fonctionnel documenté.
- Les permissions dangereuses font l'objet d'une revue spécifique.
- Principe de moindre privilège appliqué.

Terminaux

- Terminaux de développement/test : non rootés, non jailbreakés.
- Sideloading réservé aux environnements de test isolés.
- Terminaux professionnels accédant à des apps sensibles : enrôlés dans le MDM.

US11 — Choix d'une solution MDM

Critère	Microsoft Intune	VMware Workspace ONE
Modèle de déploiement	Cloud (SaaS Azure)	Cloud ou on-premise
Intégration écosystème	Microsoft 365, Entra ID, Defender	Multi-éditeur, VMware
Support Android	Android Enterprise complet	Android Enterprise complet
Gestion des applications	MAM / MDM	MAM / MDM / MCM
Conditional Access	Natif (Entra ID)	Via intégration IdP
Conformité RGPD	Hébergement EU disponible	Hébergement EU disponible
Coût	Inclus dans M365 E3/E5	Licence séparée
Complexité déploiement	Faible à modérée	Modérée à élevée
Reporting sécurité	Defender for Endpoint	Workspace ONE Intelligence

Recommandation

Microsoft Intune est recommandé pour les organisations déjà sur Microsoft 365. L'intégration native avec Entra ID simplifie la gestion des identités et le Conditional Access. Le coût est nul si la licence M365 E3 est déjà en place.

Workspace ONE est pertinent pour les environnements hétérogènes (multi-OS, on-premise critique) ou les infrastructures VMware existantes.

Politiques MDM recommandées

- Chiffrement du stockage obligatoire
- PIN / biométrie obligatoire
- Version Android minimum : 10 (API 29)
- Sideloading interdit — sources inconnues bloquées
- Accès conditionnel : terminal non-conforme → accès révoqué
- Détection de root : terminal rooté → accès bloqué

Annexes

A. Environnement technique

Outil	Version	Usage
sha256sum	GNU coreutils	US1 — vérification intégrité
MobSF	v4.5.0 (mobsf.live)	US2 — analyse automatisée
unzip	6.0	US3 — extraction fichiers
Apktool	2.9.3	US4, US6 — décompilation / recompilation
strings (binutils)	GNU	US5 — extraction chaînes DEX
keytool	OpenJDK 21	US7 — génération keystore
apksigner	31.0.2	US7 — signature APK
curl	7.x	US8 — test Firebase

B. Structure GitHub du projet

```
/ (racine du dépôt)
├── US1/ — hash_verification.md
├── US2/ — AppSec_Scorecard.pdf + vulnerabilities_summary.md
├── US3/ — AndroidManifest.xml + classes.dex (hashs SHA-256)
├── US4/ — app_src.zip
├── US5/ — strings_findings.md
├── US6/ — rebuilt.apk + build.log
├── US7/ — rebuilt_signed.apk + apksigner_verify.txt
├── US8/ — firebase_check.md + curl_response.txt
├── US9/ — rapport_final.pdf
├── US10/ — politique_mobile.md
└── US11/ — mdm_recommandation.md
```